

TURNITIN REPORT

X24211371_CA-Report.pdf

 dfeg Research 1 UPES: University of Tomorrow

Document Details

Submission ID

trn:oid::1:3602942005

Submission Date

Jun 28, 2026, 9:31 PM GMT+5:30

Download Date

Jun 28, 2026, 9:40 PM GMT+5:30

File Name

X24211371_CA-Report.pdf

File Size

210.9 KB

3 Pages**1,992 Words****11,472 Characters**

0% detected as AI

The percentage indicates the combined amount of likely AI-generated text as well as likely AI-generated text that was also likely AI-paraphrased.

Caution: Review required.

It is essential to understand the limitations of AI detection before making decisions about a student's work. We encourage you to learn more about Turnitin's AI detection capabilities before using the tool.



0 AI-generated only 0%

Likely AI-generated text from a large-language model.



0 AI-generated text that was AI-paraphrased 0%

Likely AI-generated text that was likely revised using an AI-paraphrase tool or word spinner.

Disclaimer

Our AI writing assessment is designed to help educators identify text that might be prepared by a generative AI tool. Our AI writing assessment may not always be accurate (i.e., our AI models may produce either false positive results or false negative results), so it should not be used as the sole basis for adverse actions against a student. It takes further scrutiny and human judgment in conjunction with an organization's application of its specific academic policies to determine whether any academic misconduct has occurred.

Tenant-Aware Enforcement in Multi-Tenant SaaS: A Data Governance, Compliance and Ethics Evaluation

Pavan Sai Bodduluru

Student ID: X24211371

MSc in Cloud Computing, National College of Ireland, Dublin, Ireland

H9DGCE - Data Governance, Compliance and Ethics

Abstract— The data-governance, compliance and ethical aspects of a single tenant-aware enforcement model for multi-tenant Software-as-a-Service (SaaS) with tenant context propagated end-to-end through JSON Web Token (JWT) authentication, application middleware, database row-level security (RLS) and Redis-based multi-dimensional quota management have been assessed in this report. While it is tested on synthetic tenant data and through a series of isolated penetration tests, the General Data Protection Regulation's requirements for the security-of-processing and data-protection-by-design are taken into account in the architecture and remain within scope not outside of it. Based on the GDPR and ISO/IEC 27001:2022, NIST SP 800-63B and NIST SP 800-207, the ACM Code of Ethics, and ISO/IEC 29147:2018, the fairness, accountability, transparency, and data protection aspects of design, implementation, and post-deployment are followed, and it is concluded that the main—and partially competing—obligations of the project are cross-tenant isolation and responsible disclosure.

Keywords—Multi-tenant SaaS, tenant isolation, data protection by design, JWT authentication, fairness, accountability, responsible disclosure.

I. INTRODUCTION

Multi-tenant SaaS co-houses several organisations on shared infrastructure to achieve economies of scale, yet presents two continuous governance challenges: Cross tenant data leakage – a tenant accesses another tenant's data, and the noisy neighbour effect – a tenant's resource consumption negatively impacts other tenants [1, 2]. These are due to the fact that authentication, database isolation and quota enforcement are usually implemented as distinct subsystems with their own consistent tenant context [3]. This project's evaluation combines four: JWT authentication (carrying tenant/role claims), middleware (with ORM query interceptors), PostgreSQL row-level security, and a multi-dimensional quota engine based on atomic Redis counters, providing full tenant identity enforcement across the entire application. It is tested for cross-tenant security (zero unauthorised access after 10,000 attempts), performance and fairness of resource usage (Jain's index is above 0.9). It aims to demonstrate that integrated tenant-aware enforcement increases security without undesired performance, or fairness, cost.

The governance or value added is that tenant isolation is not just a technical aspect but a data-protection control. The experiment is done with synthetic tenant data and only with the researcher's own systems; a credible data-minimisation

and responsible-testing decision, but it is still designed to work on real customer data in production. The GDPR is therefore applicable at the design level; Article 5(1)(f) integrity and confidential processing, Article 25 data protection by design, Article 32 security of processing are all applicable to the design, which is regulated in Ireland through the Data Protection Act 2018 [4] and [5]. It is also based on ISO/IEC 27001:2022, Information-security management [6], NIST SP 800-63B, Digital identity [7] and NIST SP 800-207, Zero-trust [8] and the ACM Code of Ethics [9] and ISO/IEC 29147:2018, Responsible disclosure [10]. The report, which looks at each step, makes the case that the governance requirements of the framework are not lighter, but heavier, when it's designed to hold actual tenant data.

II. EVALUATION

A. Design & Architecture

The design principle of the framework—taking tenant context from token to query—is a data-protection-by-design control. Cross-tenant leakage is the most prevalent threat and GDPR Article 25 and Article 32 call for isolation to be engineered in rather than added on later [4] and ISO/IEC 27001:2022 Annex A is a governed requirement for access control [6]. When used with PostgreSQL row-level security, JWT tenant claims provide defence in depth, ensuring isolation even when there is a mistake in the application layer [11] [12]. Importantly, a single middleware path without the tenant filter will defeat RLS, and RLS is vendor-specific, making it dependant on the specific database engine for its assurance and not portable. Comparing shared-schema RLS with schema-per-tenant and database-per-tenant isolation is a governance decision as well, and has to be balanced against better physical separation and the costs and complexity of operation.

Having tenant and role claims in the JWT means every access decision is self descriptive and auditable, enhancing accountability. This is governed by NIST SP 800-63B [7] and a zero-trust posture – verify everything, trust no position – follows NIST SP 800-207 [8]. This is an enhancement to the per-request database lookup for tenant context [13]. However, the conclusion is that adding claims expands the trust surface of the token: If the token is forged or leaked, the access is granted directly, and thus short token life, key rotation and signature verification become governance critical; and trust-evaluation schemes like TRBAC introduce expense that needs to be justified by the design [14]. Federated identity further extends the trust boundary beyond the service providers, and

the identity-provider's assurance posture becomes part of the system's compliance posture as well.

Resource quotas are not only a performance measure, they are a measure of fairness. The ACM Code of Ethics §1.4 suggests that allocation should be done in an equitable manner which means it ought to be fair [9] and Jain's index quantifies distributive fairness among tenants [2], [15]. Atomic Redis counters consistently apply API, storage, and compute limits. However, a policy that pays tenants according to how flat their usage is can also be unfair; if one tenant is legitimately bursty or bigger, he could be as throttled as an abusive customer, and hard limits, no matter what they are, without an appeals process can negatively affect the ones who need the service the most. Therefore, there is an uneven distribution of impacts on stakeholders among small tenants, enterprise customers, operators, the provider and the regulator.

B. Implementation & Operation

Adversarial testing is necessary for validation of isolation: 10,000 tests across JWT tenantID manipulation, JWT token forgery, SQL injection and quota abuse were performed on the researcher's own instances. Limiting attacks to one's own systems is the proper ethical limit which is also in accordance with the ACM Code §2.8 to access only authorised resources [9]. Since the methods used are "dual use", the ISO/IEC 29147:2018 responsible-disclosure policy is in force: the study promises to report vulnerabilities and mitigations but not the specifics of exploits [10]. The limitation is that ISO/IEC 29147 regulates process rather than distinguishing between information that is 'instructive' and information that is 'weaponisable', so the researcher must make his/her own judgement, but no standard provides it.

A non-reconstructable access decision cannot be governed. Every decision made within the tenants scope is logged in a zero-trust design using ORM interceptors [8] and ISO/IEC 27001:2022 Log and Monitor controls are used as accountability mechanism. This makes enforcement open and subject to challenge. The tension is the audit logs are themselves as sensitive as the operational metadata that is recorded, including access patterns and tenant identifiers, which are protected under GDPR; operational metadata access controls, retention and protection requirements must not turn into evidence confidentiality risks when applied to the audit logs.

If isolation is mis-enforced, a framework can also give the illusion of security. GDPR Article 32's confidentiality-and-integrity requirement, along with the zero-trust verification requirement both require enforcement to be tested and not assumed [4], [3]. If the breach count was a binary number, meaning that if there had been 10,000 logins and no unauthorised access, then it would be a governance measure instead of a quality assurance one, as it would show 0 [14]. However, even if no breaches are detected, it does not imply that the system is impossible to breach, and the result is limited by the vectors tested; the production assurance must therefore be continuous, but it also requires compliance monitoring and internal audit following the ISO/IEC 27001 Plan-Do-Check-Act cycle [6]. Incorporating all isolation claims into a continuously updated control turns ad hoc assurance into governed assurance.

C. Post-Deployment Implications

Open science is encouraged by publishing the code, configuration, and synthetic datasets, as this allows others to

reproduce the security claims [9] and using synthetic tenants instead of real customer data is also a privacy-preserving choice. The downside of an open enforcement framework published with its attack vectors is that it is dual-use, mitigation and outcome information can be published while the vectors are not.

Another consideration after deployment is sustainability. Even though the cloud compute cost of repeated k6/YCSB tests is significant, the cloud cost of operation is more significant: every time a request is made, JWT is verified, RLS is used for filtering, Redis counters are queried, and so on – so energy-efficient enforcement is a green-software-engineering necessity. However, the audit and quota log files also accumulate over time, and according to ISO/IEC 27001:2022 that will require a retention/deletion schedule, not indefinite accumulation, and the GDPR will require adherence to the "data minimisation" principle [6, 4].

Also, automated quota enforcement focuses control and can introduce bias in automated behaviour, systematically disadvantage atypical, bursty, or larger tenants – an incorrectly throttled tenant should have a transparent appeal and human-override path to retain user agency, tenants should be able to see how they are being isolated. Relying on the row-level security and specific token libraries offered by the vendor creates vendor lock-in, is an accountability and portability problem and needs to be re-validated regularly because of the changing scope of the algorithms and threats that these security assurances cover. These duties— isolation, disclosure, fairness and enforceable and sustainable—should not be optimised in isolation.

REFERENCES

- [1] F. Khoda Parast, C. Sindhav, S. Nikam, H. Izadi Yekta, K. B. Kent, and S. Hakak, "Cloud computing security: A survey of service-based models," *Comput. Secur.*, vol. 114, art. no. 102580, 2022, doi: 10.1016/j.cose.2021.102580.
- [2] A. Cheng, A. Kabcenell, X. Shi, J. Huey, P. Bailis, N. Crooks, and I. Stoica, "Fair transaction processing for multi-tenant databases," *Proc. VLDB Endowment*, vol. 18, no. 8, pp. 2602–2615, 2025, doi: 10.14778/3742728.3742751.
- [3] R. Wang, C. Li, K. Zhang, and B. Tu, "Zero-trust based dynamic access control for cloud computing," *Cybersecurity*, vol. 8, art. no. 12, 2025, doi: 10.1186/s42400-024-00320-x.
- [4] General Data Protection Regulation, Regulation (EU) 2016/679, European Parliament and Council, Off. J. Eur. Union, vol. L119, pp. 1–88, May 2016.
- [5] Data Protection Act 2018, no. 7 of 2018, Acts of the Oireachtas, Ireland, 2018.
- [6] Information Security, Cybersecurity and Privacy Protection - Information Security Management Systems - Requirements, ISO/IEC 27001:2022, ISO, Geneva, Switzerland, 2022.
- [7] P. A. Grassi, J. L. Fenton, E. M. Newton, et al., "Digital identity guidelines: Authentication and lifecycle management," NIST, Gaithersburg, MD, USA, Special Publication 800-63B, Jun. 2017, doi: 10.6028/NIST.SP.800-63b.
- [8] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST, Gaithersburg, MD, USA, Special Publication 800-207, Aug. 2020, doi: 10.6028/NIST.SP.800-207.
- [9] ACM, "ACM code of ethics and professional conduct," Association for Computing Machinery, New York, NY, USA, 2018.
- [10] Information Technology - Security Techniques - Vulnerability Disclosure, ISO/IEC 29147:2018, ISO/IEC, Geneva, Switzerland, 2018.
- [11] H. Dong, C. Zhang, G. Li, and H. Zhang, "Cloud-native databases: A survey," *IEEE Trans. Knowl. Data Eng.*, vol. 36, no. 12, pp. 7772–7791, 2024, doi: 10.1109/TKDE.2024.3397508.
- [12] V. Narasayya and S. Chaudhuri, "Multi-tenant cloud data services: State-of-the-art, challenges and opportunities," in *Proc. ACM*

SIGMOD Int. Conf. Manag. Data (SIGMOD '22), 2022, pp. 2465–2473, doi: 10.1145/3514221.3522566.

- [13] M. Yassin, H. Ould-Slimane, C. Talhi, and H. Boucheneb, "Multi-tenant intrusion detection framework as a service for SaaS," *IEEE Trans. Services Comput.*, vol. 15, no. 5, pp. 2925–2938, 2022, doi: 10.1109/TSC.2021.3077852.
- [14] U. R. Saxena and T. Alam, "Provisioning trust-oriented role-based access control for maintaining data integrity in cloud," *Int. J. Syst. Assur. Eng. Manag.*, vol. 14, no. 6, pp. 2559–2578, 2023, doi: 10.1007/s13198-023-02112-x.
- [15] C. Zheng, Q. Zhuang, and F. Guo, "A multi-tenant framework for cloud container services," in *Proc. IEEE 41st Int. Conf. Distrib. Comput. Syst. (ICDCS)*, 2021, pp. 359–369, doi: 10.1109/ICDCS51616.2021.00042.